Détection d'intrusion réseau explicable

Classification supervisée et explicable de flux réseau (CSE-CIC-IDS2018, infrastructure AWS) — Projet Challenge 1, Data Mining, ENSI 2026-2027 — Farah Grissa

Code : github.com/Farahgrissa/ids-xai-classification · **Application :** ids-xai-classification.streamlit.app · **API :** ids-xai-api.onrender.com/docs

37 395
flux analysés après nettoyage (27 % d'attaques)

0,994
PR-AUC de XGBoost sur un jeu de test jamais vu

98 %
des attaques détectées (rappel, seuil 0,5)

≈ 1 %
du trafic normal signalé à tort

4 ms
pour classer 1 000 flux : compatible temps réel

PROBLÈME MÉTIER

Un centre opérationnel de sécurité (SOC) reçoit des millions de flux réseau par jour. Il lui faut un détecteur qui **repère les attaques sans noyer les analystes sous les fausses alertes**, et qui **justifie chaque alerte** pour qu'elle soit vérifiée en quelques secondes.

DONNÉES

- **CSE-CIC-IDS2018**, trafic capturé sur AWS, téléchargé automatiquement depuis le bucket S3 public.
- 3 familles d'attaques : **force brute** (FTP, SSH), **déni de service** (Hulk, SlowHTTPTest), **botnet**. Cible binaire : normal / attaque.
- **Qualité :** 21 % de doublons supprimés ; étiquettes incohérentes détectées (flux identiques étiquetés FTP et SlowHTTPTest).
- **Raccourcis exclus :** heure, port de destination et variables d'« empreinte système » (taille de fenêtre TCP), qui identifient la machine plutôt que le comportement.

DÉMARCHE ET MEILLEUR MODÈLE

Cinq modèles comparés en validation croisée stratifiée (5 plis), hyperparamètres optimisés (GridSearch, RandomizedSearch), critère **PR-AUC** adapté au déséquilibre des classes.

Modèle (jeu de test)	PR-AUC	Rappel	Précision	ms / 1 000
XGBoost (retenu)	**0,994**	**0,982**	**0,973**	**4**
Random Forest	0,993	0,981	0,976	11
Arbre de décision	0,985	0,979	0,968	3
KNN	0,977	0,978	0,970	53
Régression logistique	0,898	0,960	0,815	4

XGBoost égale Random Forest en performance, prédit 2 à 3 fois plus vite et ne surapprend pas (écart validation / test $< 0{,}003$, donc aucune fuite de données).

RÉSULTATS EN CONDITIONS RÉELLES

Sur le test, XGBoost manque environ 37 attaques sur 2 043, principalement des DoS Hulk dont le serveur saturé ne répond plus (flux vides, proches de connexions normales interrompues).

> **Effet du taux de base.** Le test contient 27 % d'attaques, un vrai réseau moins de 1 %. À taux de fausses alertes égal, la précision passe alors de 97 % à **environ 50 %** : une alerte sur deux serait fausse. Relever le seuil de 0,5 à 0,9 n'apporte que quelques points de précision et double le nombre d'attaques manquées.

POURQUOI LE MODÈLE DÉCIDE (SHAP, LIME)

- **Le rythme d'abord** (1re variable SHAP) : un intervalle de 0,1 à 50 ms entre paquets envoyés pousse vers l'attaque, au-delà de 0,1 s vers le normal. Effet en cloche, hors de portée d'un modèle linéaire.
- **Puis le contenu et TCP** : aucun octet échangé (requête sans réponse), connexion coupée par RST (+2 à +6 log-odds, signal le plus fort pour le botnet).
- **Une alerte expliquée** : Hulk à 98 % = deux paquets à 8,4 ms d'écart, aucun octet renvoyé. Une phrase de synthèse est générée pour chaque flux (application et API `/explain`).
- **Fausse alerte comprise** : un flux normal court et sans réponse (33 ms) a exactement le profil Hulk.
- **SHAP et LIME cohérents**, et avec l'intuition métier, si LIME est réglé localement : 2,8 variables communes sur 5, même sens. Avec son noyau par défaut, LIME n'est pas fidèle (R^2 0,13).

ANALYSE CRITIQUE

- **Variables sensibles et équité.** Aucune donnée personnelle (adresses IP exclues). L'équivalent est l'**empreinte système** : remise dans le modèle, elle devient la 1re raison SHAP (36 % de l'importance) et une fenêtre TCP de 225 donne 100 % d'attaques. Le modèle jugerait la machine, pas son comportement : elle est exclue (PR-AUC 0,9997 → 0,9936). Biais restant : l'UDP est appris comme normal.
- **Performance ou interprétabilité.** La régression logistique perd 10 points de PR-AUC, produit **9 fois plus de fausses alertes**, et ses contributions SHAP se compensent (± 50 log-odds) : elle n'est pas plus lisible. Recommandation : **XGBoost avec une explication SHAP par alerte**.

ACTIONS POUR LE DÉCIDEUR

- **Seuil autour de 0,8**, ajusté à la capacité de traitement de l'équipe.
- **Afficher la phrase et les contributions SHAP** de chaque alerte pour vérifier en quelques secondes.
- **Agréger par source et par fenêtre de temps** : un flux court sans réponse isolé est une fausse alerte probable, une rafale une attaque.
- **Enrichir l'entraînement** (attaques UDP, FTP), recalibrer sur le trafic réel, surveiller la dérive des variables de rythme.

LIMITES

- Données de laboratoire et taux d'attaques irréaliste : la précision mesurée est optimiste.
- Classification flux par flux : la répétition, signature de la force brute, n'est pas exploitée.
- SHAP explique le modèle, pas la cause réelle ; LIME dépend du voisinage choisi.